
Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

1/25

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"
Deliberation no. 6FR/2023 of July 5, 2023

The National Commission for Data Protection sitting in a restricted formation, composed of Ms. Tine A. Larsen, President, and Messrs. Thierry Lallemand and Marc Lemmer, Commissioners;

Considering the regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC;

Considering the law of August 1, 2018, organizing the National Commission for Data Protection and the general regime on data protection, in particular its Article 41;

Considering the internal rules of the National Commission for Data Protection adopted by decision no. 3AD/2020 dated January 22, 2020, in particular its Article 10.2;

Considering the regulation of the National Commission for Data Protection regarding the investigation procedure adopted by decision no. 4AD/2020 dated January 22, 2020, in particular its Article 9;

Considering the following:

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

2/25

I. Facts and Procedure

1. On March 10, 2021, the National Commission for Data Protection (hereinafter: the "CNPD" or the "National Commission") received a complaint from Ms. [...] (hereinafter: "the complainant") regarding the publication of her [data] [on the website] of Company X (hereinafter: "Company X") and reporting to the CNPD potential violations of the provisions of regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (hereinafter: the "GDPR").

2. In the course of investigating the complaint, it appeared that Company B [...] had transferred the personal data of the complainant to Company A, which in turn transferred said data to Company X. During its deliberation session on July 1, 2022, the National Commission for Data Protection sitting in plenary formation decided to open an investigation into Companies B, C, and A based on Article 38 of the law of August 1, 2018, organizing the National Commission for Data Protection and the general regime on data protection (hereinafter: "law of August 1, 2018") and to appoint Mr. Alain Herrmann as the head of the investigation.

3. The said decision specified that the investigation conducted by the National Commission aimed to verify the application and compliance by the three aforementioned companies "with the provisions of the GDPR, in particular those relating to the lawfulness of processing, the obligation to inform the data subject regarding the transfer of their data to third parties, and the right to erasure, in the specific context of the transfer of the complainant's personal data to a third party company."

4. Company A is registered in the Luxembourg Trade and Companies Register under number [...] and has its registered office at [...], [...] [...] (hereinafter: the "controlled entity"). It [offers electronic communications services].¹

¹ See Article [...] of the coordinated statutes of [...].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

3/25

5. The decision of the National Commission sitting in a restricted formation (hereinafter: the "Restricted Formation") on the outcome of the investigation will be based on:

- the processing carried out by the controlled entity in the context of the aforementioned complaint and verified by the agents of the CNPD; and
- the legal and regulatory provisions taken into account by the head of the investigation in his communication of grievances.

6. The controlled entity was informed of the opening of the investigation against it by letter from the head of the investigation dated August 23, 2022. It appears from this letter that the head of the investigation had defined the following control objectives:

- “• Determine the legal qualification of the controlled entities in relation to the GDPR in order to know which entity/entities is/are responsible for the processing and/or subcontracting;
- Verify the legality of the transfer of personal data of the complainant by Company B to Company A and/or C;
- Verify the legality of the transfer of personal data of the complainant by the mentioned entities to Company X;
- Verify compliance by the processing entity/entities with its obligation to inform the data subject regarding the transfer of personal data to a third party;
- Verify that the processing entity/entities has/have complied with the request for erasure and/or the right to object of the data subject.”

7. The letter was accompanied by a document titled “Initial Findings Investigation No. [...]” outlining the initial findings made by the agents of the CNPD based on the documents collected in the context of the complaint and submitted to the present investigation (hereinafter: the “initial findings”). The head of the investigation offered the controlled entity the opportunity to “challenge the facts included in the initial findings, or to provide [its] possible comments, clarifications, or additions” by October 7, 2022, at the latest.

8. The controlled entity responded by letter dated October 7, 2022.

9. At the end of his investigation, the head of the investigation notified the controlled entity on January 25, 2023, of a communication of grievances detailing the shortcomings he believed were constituted in this case regarding the requirements prescribed by Article 32.1 of the GDPR (obligation to ensure appropriate security) and by Article 31 of the GDPR (obligation to cooperate with the supervisory authority).

The head of the investigation proposed to the Restricted Formation to adopt three different corrective measures, as well as to impose an administrative fine of 5,330 euros on the controlled entity.

The opportunity to submit written observations on the communication of grievances was offered to the controlled entity. The latter did not provide any observations to the head of the investigation.

10. The president of the Restricted Formation informed the controlled entity by letter dated March 13, 2023, that its case would be included in the agenda of the Restricted Formation meeting on April 27, 2023, and that it was offered the opportunity to be heard. By email dated April 18, 2023, the controlled entity confirmed its presence at said meeting.

During this meeting, the head of the investigation and the controlled entity, represented by Mr. [...], presented their oral observations in support of their written observations and answered questions posed by the Restricted Formation. The controlled entity had the last word.

II. In law

II.1. On the quality of the controlled entity regarding the processing in question

1. On the principles

12. In accordance with Article 4 point 7) of the GDPR, the data controller is “the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing [...]”.

11. Article 4 point 8) of the GDPR defines the processor as “the natural or legal person, public authority, agency, or other body which processes personal data on behalf of the controller.”

12. The European Data Protection Board (hereinafter: the “EDPB”) has provided further explanations in its guidelines on the concepts of controller and processor (hereinafter “guidelines 07/2020”) which “play a crucial role in the application of the [GDPR], as they determine who is responsible for compliance with the various rules on data protection and how data subjects can exercise their rights in practice.” It

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

4/25

is essential to clarify these roles to ensure accountability and compliance with the GDPR.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

5/25

it is specified that the aforementioned concepts are "functional concepts in that they aim to allocate responsibilities based on the actual roles played by the parties and autonomous concepts in that they must be interpreted primarily according to EU legislation on data protection." 2

13. Furthermore, the EDPB clarified in the aforementioned guidelines that a "new distinct feature of the GDPR lies in the provisions directly imposing obligations on processors. [...] In this regard, the [EDPB] considers that Article 28, paragraph 3, of the GDPR, while imposing specific content on the contract that must be concluded between the data controller and the processor, imposes direct obligations on processors, notably the obligation to assist the data controller in ensuring compliance with the rules."3

14. Similarly, it follows that both "data controllers and processors may be subject to fines in the event of non-compliance with the obligations imposed by the GDPR that concern them, and both are directly accountable to the supervisory authorities under the obligations to maintain and provide appropriate documentation upon request, to cooperate with investigations, and to comply with administrative orders. At the same time, it should be recalled that processors must always comply with the instructions of the data controller and act solely according to those instructions."4

2. In this case

15. By email dated July 21, 2021, the controlled party explained that Company B [...]."

16. Following additional questions from the head of the investigation⁵, the controlled party informed him in a letter dated October 6, 2021⁶ of the existence of a collaboration contract concluded between Company C and Company A setting out the operational conditions and activities of Company B, as well as the rights and obligations of the parties.⁷ It is stated that "Company A has, among other things, the mission to manage/modify/delete the [...] [subscriber lists] of Company B." The controlled party concluded in the said letter that "the quality of data controller of personal data is attributed to both parties. Company C and Company A are jointly responsible for processing."

17. On the other hand, in a letter dated October 7, 2022, the controlled party expressed "surprise at the response you received in the letter dated October 6, 2021 (document number 9) in which the employee claims that Company A would be jointly responsible for processing with Company C. Indeed, Company A is a processor on behalf of Company B. We apologize for these dubious responses. [...] ." Attached to the aforementioned letter was a document titled "AMENDMENT TO THE SUBCONTRACTING AGREEMENT CONCLUDED BETWEEN COMPANIES 'B' AND 'A'

REGARDING THE PROCESSING OF DATA IN ACCORDANCE WITH THE GENERAL DATA PROTECTION REGULATION (EU) 2016/679 OF APRIL 27, 2016, APPLICABLE FROM MAY 25, 2018" (hereinafter: the "subcontracting agreement").

18. The Restricted Formation notes that Article [...] of the said subcontracting agreement indeed describes the tasks of the controlled party in its capacity as a processor for Company B as follows: [The controlled party] is authorized to process on behalf of [Company B] the personal data necessary for [the controlled party] to manage the administrative aspect of the subscriptions generated by [Company B].

The nature of the operations performed on the data is:

- Consultation/processing of personal data
- Temporary backup of data
- Import of personal data
- Modification of data
- Any other use necessary for the maintenance of the service.

The purpose(s) of the processing are the administrative management of the subscriptions generated by [Company B] and the provision of services to clients [of Company B].

The personal data processed includes all identification data of clients [of Company B] (name, first name, full address, phone number, copy of contract) as well as the data necessary for the management of the client's subscription contract [of Company B].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

6/25

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

7/25

The categories of persons concerned are all clients who subscribed to a contract with [Company B].

19. As the complainant subscribed on April 27, 2015, to a subscription contract with Company B, the latter is to be considered as the data controller of the complainant's personal data in the context of said contract, while the controlled entity acts in this specific context as a processor for Company B tasked with managing/modifying/deleting the [subscriber lists] on behalf of said company in accordance with the aforementioned subcontracting agreement.

20. During the Restricted Formation session on April 27, 2023, the controlled entity confirmed the aforementioned roles of Company B and Company A, while specifying that the two entities do not share a common client database and that each has its own IT system. Nevertheless, under the subcontracting agreement, staff members of the controlled entity would have access to Company B's IT system to carry out the necessary operations on its behalf, notably to generate a file [...] with clients wishing to appear [on the website] of Company X, on the one hand, and to send said file monthly to Company X (unless there have been no changes compared to the previous month), on the other hand.

II. 2. On the grounds for the decision

A. On the breach related to the obligation to ensure appropriate security

1. On the principles

21. Under Article 32.1 of the GDPR and "taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk including, among other things, as necessary:

- a) the pseudonymization and encryption of personal data;
- b) means to ensure the ongoing confidentiality, integrity, availability, and resilience of processing

systems and services;

8 See document 2 attached to the communication of grievances.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

8/25

c) means to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;

d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of the processing."

22. It should be noted that the EDPB specified in guidelines 07/2020 that the "GDPR establishes obligations that are directly and specifically applicable to processors" and that a "processor may be held liable or fined for non-compliance with these obligations or if it exceeds or infringes the legal instructions of the data controller." One of these obligations is precisely that a processor must implement appropriate technical and organizational measures in accordance with Article 32 of the GDPR.

2. In this case

23. The subscription contract concluded on April 27, 2015, between the complainant and Company B ended on June 30, 2019.

However, it appears from the initial findings that in October 2020, following a telemarketing call for religious purposes, the complainant realized that her [data] had been published [...] on the website of Company X and that said [data] had been transferred by the controlled entity to Company X for publication [on said site]. On October 19, 2020, Company X confirmed to the complainant that her data would be removed from its website.

However, on March 10, 2021, the complainant's [data] was again available on the website of Company X, the latter claiming that said [data] had once again been transferred to it by the controlled entity for publication [on its site].

24. In a letter dated June 1, 2021, the controlled entity specified that it had the "mission to manage/modify/delete the [subscriber lists] on behalf of Company B," on the one hand, and that Company X had contacted its services on March 29, 2021, to inform it of the complainant's wish to no longer appear [on its site], on the other hand.

Furthermore, in the same letter, the controlled entity explained that, as the complainant had not been subscribed to Company B since June 30, 2019, "her [data] would not have been...

9 EDPB, Guidelines 07/2020, point 74.

10 See findings 1 to 7 of the initial findings.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

9/25

therefore should not have been transferred to Company X [in] 2021. This transfer resulted from an internal configuration error, and corrective measures have been taken to remedy it."

25. However, following a new telemarketing call for religious purposes addressed to the complainant on March 5, 2022, it became apparent that her [data] had again been published [on the site] of Company X, the latter claiming that this publication occurred following a transfer of said [data] by the controlled entity to Company X in February 2022.¹¹

26. By letter dated October 7, 2022, the controlled entity acknowledged that Company X had already requested the deletion of the complainant's data "on October 19, 2020, without a response from us, with a follow-up on March 29, 2021. We complied with the request on that date, and the complainant's data has not been transmitted to Company X thereafter." In the same letter, the controlled entity also

formally contested having transferred the complainant's data to Company X again in February 2022 and insisted "that since March 29, 2021, [the complainant] is no longer on the lists transmitted by Company A to Company X, as evidenced by the file sent to Company X on April 15, 2021, which we can provide you if necessary."

27. Following this contestation, the head of the investigation requested the controlled entity by letter dated December 6, 2022, "to provide us with the communications as transmitted, in their exact form and without any alteration, by Company A to Company X of the subscriber data of Company B that should appear [on the site] of Company X, on the following dates: Communications from April and May 2021; Communication of February 23, 2022, and for the months of March, April, May, June, July, August, September, and October 2022."

28. The controlled entity sent the requested documents by email dated December 14, 2022.

29. In the statement of objections dated January 25, 2023, the head of the investigation noted that Company X received from the controlled entity the complainant's data to display [on its site] in 2020 and 2021, while the subscription of Company B for the complainant ended on June 30, 2019, "from which date the Controlled, as a subcontractor of Company B, should have ceased transferring the personal data of the Complainant to Company X."¹²

¹¹ See findings 16 and 17 of the initial findings.

¹² Statement of objections, points 20 and 21.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

10/25

30. Furthermore, it was noted that the personal data of the complainant again appeared in the file containing the data of the subscribers of Company B as transmitted in February 2022 by the controlled entity to Company X, so that these individuals would appear [on the website] of Company X, on the one hand, and that a "Ctrl+f" search in said file [...] "does indeed show that the complainant's data is present among the data of the subscribers of Company B to be displayed [on the site] of Company X," on the other hand.¹³

Thus, the head of the investigation concluded that "the conditions of Article 32, paragraph 1, of the GDPR were not respected, the Controlled having failed to implement appropriate technical and organizational measures, on the one hand, to ensure the confidentiality of the personal data of the Complainant and thus prevent them from being transferred to Company X following the termination of her subscription contract with Company B and, on the other hand, to regularly test, analyze, and evaluate the effectiveness of said measures."¹⁴

31. The Restricted Formation notes in this context that since June 30, 2019, the date of termination by the complainant of the subscription contract with Company B, the complainant should no longer have appeared on the list of subscribers wishing to appear [on the website] that the controlled entity typically transmits monthly on behalf of Company B to Company X. However, the controlled entity transmitted the [data] of the complainant precisely for the purpose of publication [on the website] in 2020, in 2021, as well as in February 2022. Indeed, the controlled entity sent on December 14, 2022, among other things, the email and the file [...] sent on February 15, 2022, to Company X containing the [data] of the subscribers of Company B wishing to appear [on the site] of Company X, still including those of the complainant.

32. By email dated June 1, 2021, the controlled entity admitted that it should not have transferred the complainant's data to Company X and that it was an "internal configuration error," while in a letter dated October 7, 2022, it "thought that these shortcomings occurred due to successive human errors. Indeed, the period of the dispute is situated at the heart of the crisis related to Covid-19. Our teams often had to work understaffed during the crisis due to numerous work stoppages, isolations, and family-related leave. Furthermore, given the urgency of the situation, we had to modify

¹³ Statement of objections, points 24 and 25.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

11/25

our work organization and hastily implement a presence rotation in the company."

33. In the same letter, the controlled party acknowledged that Company X had already requested the deletion of the complainant's data "on October 19, 2020, with no response from us and a follow-up on March 29, 2021. We complied with the request on that date, and the client's data has not been transmitted to Company X since then."

34. During the Restricted Formation session on April 27, 2023, the controlled party further confirmed that, contrary to previous assertions, the [data] of the applicant was indeed still present in the file transmitted in February 2022 to Company X. He explained that these irregular transmissions were linked to an internal IT problem, as at the time the complainant's subscription with Company B was terminated, in 2019, the registration in the file of individuals wishing to appear [on the site] of Company X had not been automatically deleted. According to the controlled party, this update in the IT system of Company B [...] would not have been made until March 2022.

35. Regardless of the reasons that led to these irregular transmissions of the complainant's [data] to Company X, the Restricted Formation first notes that it follows from the preceding findings that the controlled party did not have a specific procedure established to regularly test and analyze whether the lists of [data] transmitted to Company X did not include subscribers who had either terminated their subscription contract with Company B or requested to no longer appear [on the website].

36. Secondly, the Restricted Formation notes that the requests for deletion of the complainant's data by Company X dated October 19, 2020, and March 29, 2021, should have led the controlled party to conduct investigations into its security system. However, as the complainant's [data] was once again transferred to Company X on February 15, 2022, the Restricted Formation considers that the measures deployed to ensure data security in this case were insufficient and did not meet the minimum necessary requirements in terms of security.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

12/25

37. In light of the above, the Restricted Formation aligns with the opinion of the head of the investigation and concludes that at the beginning of the investigation¹⁵, the controlled party failed to fulfill its obligation under Article 32.1 of the GDPR.

38. As for the measures taken by the controlled party after the start of the investigation, the Restricted Formation will return to this in point 58, as well as in Chapter II.3, Section 2.2. of this decision.

B. On the breach related to the obligation to cooperate with the supervisory authority

1. On the principles

39. According to Article 31 of the GDPR, "[t]he controller and the processor, as well as, where applicable, their representatives, shall cooperate with the supervisory authority, at the request of the latter, in the performance of its tasks."

40. As mentioned in point 14 of this decision, the EDPB clarified in its guidelines 07/2020 that a "processor may be held liable or fined for non-compliance with these obligations or if it exceeds or infringes the legal instructions of the controller."¹⁶ One of these obligations is precisely that a processor must cooperate "with the supervisory authority, at the request of the latter, in the performance of its tasks," as required by the aforementioned Article 31 of the GDPR.

2. In this case

41. It follows from the communication of grievances that in the context of the complaint filed by the complainant on March 10, 2021, the CNPD had to contact the controlled party several times in 2021

and 2022 and even sent reminder letters, as it "did not respond in a timely manner to the questions posed to it. This was notably the case with a letter from the CNPD dated July 28, 2021, which was subject to a reminder on September 10, 2021, as well as a letter from the CNPD dated January 20, 2022, which was subject to a reminder on March 9, 2022, and remained unanswered. The lack of response from the Controlled Party to this last letter, which raised numerous issues, partly motivated the opening of the present investigation."¹⁷

15 That is to say at the time of receiving the letter from the head of the investigation informing the controlled party of the opening of the investigation against it dated August 23, 2022.

16 EDPB, Guidelines 07/2020, point 74.

17 Communication of grievances, points 29 and 30.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

13/25

42. Furthermore, the head of the investigation noted that "many statements made by the Controlled in the context of the Complaint were subsequently refuted in the Controlled's letter dated October 7, 2022, in response to the Initial Findings (DOCUMENT 4). The Controlled indeed explained that the responses had been formulated by one or more employee(s) and had not been validated by management before being sent to the CNPD." ¹⁸

43. Ultimately, while the Controlled had assured in its letter of October 7, 2022, in response to the initial findings, that measures had been taken as of March 29, 2021, the head of the investigation noted that the complainant's data had again been transferred by the Controlled to Company X in February 2022. According to the head of the investigation, it "is surprising that the Controlled did not implement the simplest measures, such as a 'Ctrl+f' search action in its files, in order to provide an accurate response to the questions raised by the CNPD agents in charge of the investigation. Such inaction may suggest that the Controlled intentionally sought to conceal from the CNPD agents in charge of the investigation the fact that the personal data of the Complainant had again been transferred to Company X on February 23, 2022."

For the reasons stated above, the head of the investigation concluded "that the conditions of Article 31 of the GDPR were not met, the Controlled having, on the one hand, ceased to respond to the questions of the CNPD in the context of the processing of the Complaint filed by the Complainant and, on the other hand, provided false answers that were easily verifiable in the context of this investigation." ¹⁹

44. The Restricted Formation recalls that both the data controllers and the processors "are directly accountable to the supervisory authorities under the obligations to keep up-to-date and provide appropriate documents upon request, to cooperate with investigations, and to comply with administrative injunctions." ²⁰

45. It notes in this context that certain letters, even emails from the CNPD addressed to the Controlled in the context of managing the complaint, went unanswered. ²¹

18 Communication of grievances, points 31.

19 Communication of grievances, points 33 and 34.

20 EDPB, Guidelines 07/2020, point 9.

21 See the CNPD letter dated July 28, 2021, which was followed up on September 10, 2021, as well as a CNPD letter dated January 20, 2022, which was followed up on March 9, 2022. These are documents 7, 8, 10, and 14 attached to the initial findings.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

14/25

46. In its letter of October 7, 2022, following the sending of the initial findings by the head of the investigation, the Controlled explained that "documents numbers 10 and 14 refer to emails sent by your services to our address [...], which remained unanswered on our part. We acknowledge these shortcomings upon reading the file you have sent us and wish to apologize for them. After internal analysis, this situation arises from successive resignations within our litigation department. Indeed, the department consists of two legal professionals. One of them left our staff [end] 2021 and the other, responsible for taking over the case, left our staff [beginning] 2022."

47. During the session of the Restricted Formation on April 27, 2023, the Controlled even formally contested the head of the investigation's allegation that it had not wanted to cooperate with the CNPD or that it had tried to hide something, while confirming that the [data] of the complainant were again in the file transmitted to Company X in February 2022 due to an internal IT issue.

48. The Restricted Formation first considers that a company that uses a generic email address such as "[...]" for its litigation service, which is also indicated at the bottom of the Controlled's letters, must ensure that emails sent to that address are read regularly, even in the event of the resignation of a person who worked in the relevant department.

49. It is surprised that the Controlled did not check that the [data] of the complainant were no longer in the file transmitted to Company X in February 2022 before formally contesting this allegation in its letter of October 7, 2022, while confirming "that since March 29, 2021, Ms. [...] is no longer on the lists transmitted by Company A to Company X." However, as the Controlled itself transmitted, only a week after the head of the investigation's request, notably the said file from February 2022 proving that the [data] of the complainant were again present, the Restricted Formation does not share the head of the investigation's view that the Controlled "intentionally sought to conceal from the CNPD agents in charge of the investigation the fact that the personal data of the Complainant had again been transferred to Company X on February 23, 2022." 22, but considers it to be a negligence on its part.

50. Regarding the incorrect interpretation of the quality of the Controlled concerning the processing in question expressed by an employee in a letter dated October 6, 2021 and

22 Communication of grievances, point 33.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

15/25

corrected by the controlled party in its letter of October 7, 2022, the Restricted Formation believes that this misunderstanding reflects a lack of internal communication and not a failure of cooperation by the controlled party with the CNPD.

51. Nevertheless, as the CNPD had to contact the controlled party several times in 2021 and 2022 and even sent reminder letters without response, the Restricted Formation aligns on this point with the opinion of the head of the investigation and concludes that at the beginning of the investigation, Article 31 of the GDPR was not respected by the controlled party, as it failed in its obligation to cooperate with the supervisory authority, namely, the CNPD.

II. 3. On the fine and corrective measures

1. On the principles

52. In accordance with Article 12 of the law of August 1, 2018, the National Commission has the powers provided for in Article 58.2 of the GDPR:

- "a) warn a controller or a processor that the intended processing operations are likely to violate the provisions of this regulation;
- b) reprimand a controller or a processor when the processing operations have resulted in a violation of the provisions of this regulation;
- c) order the controller or the processor to comply with requests made by the data subject in order to exercise their rights under this regulation;
- d) order the controller or the processor to bring the processing operations into compliance with the provisions of this regulation, where appropriate, specifically and within a

determined timeframe;

- e) order the controller to communicate to the data subject a personal data breach;
- f) impose a temporary or definitive limitation, including a prohibition, on processing;
- g) order the rectification or erasure of personal data or the limitation of processing in accordance with Articles 16, 17, and 18 and the notification of these measures to the recipients to whom the personal data have been disclosed in accordance with Article 17, paragraph 2, and Article 19;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

16/25

- h) withdraw a certification or order the certification body to withdraw a certification issued under Articles 42 and 43, or order the certification body not to issue a certification if the requirements applicable to the certification are not or are no longer met;
- i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the specific characteristics of each case;
- j) order the suspension of data flows addressed to a recipient located in a third country or to an international organization."

53. In accordance with Article 48 of the law of August 1, 2018, the CNPD may impose administrative fines as provided in Article 83 of the GDPR, except against the State or municipalities.

54. Article 83.1 of the GDPR provides that each supervisory authority ensures that the administrative fines imposed are, in each case, effective, proportionate, and dissuasive.

55. Article 83.2 specifies the elements that must be taken into account to decide whether to impose an administrative fine and to decide on the amount of that fine:

- "a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing concerned, as well as the number of data subjects affected and the level of damage they have suffered;
- b) whether the violation was committed intentionally or negligently;
- c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical and organizational measures they have implemented under Articles 25 and 32;
- e) any relevant previous violations committed by the controller or processor;
- f) the degree of cooperation established with the supervisory authority in order to remedy the violation and mitigate its possible negative effects;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

17/25

- g) the categories of personal data concerned by the breach;
- h) the manner in which the supervisory authority became aware of the breach, including whether, and to what extent, the data controller or the processor notified the breach;
- i) when measures referred to in Article 58(2) have previously been ordered against the data controller or the processor concerned for the same subject matter, compliance with those measures;
- j) the application of approved codes of conduct pursuant to Article 40 or approved certification mechanisms pursuant to Article 42; and
- k) any other aggravating or mitigating circumstances applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or

indirectly, as a result of the breach."

56. The imposition of administrative fines has been clarified by the Article 29 Working Party in its "Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679" adopted on October 3, 2017. These guidelines have been reiterated and reapproved by the EDPB. The Restricted Formation emphasizes that these guidelines have been supplemented by the "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" from the EDPB, the 2.0 version of which was adopted on May 24, 2023.

57. The Restricted Formation wishes to clarify that the facts taken into account in this decision are those established at the beginning of the investigation. Any subsequent changes regarding the data processing subject to the investigation, even if they fully or partially establish compliance, do not retroactively annul an established infringement.

58. Nevertheless, the actions taken by the controlled entity to comply with the GDPR during the investigation procedure or to remedy the infringements identified by the head of the investigation in the communication of grievances are taken into account by the Restricted Formation in the context of any corrective measures to be imposed and/or the determination of the amount of any potential administrative fine to be imposed.

23 See decision Endorsement 1/2018 of the EDPB of May 25, 2018, available at:

https://edpb.europa.eu/sites/edpb/files/files/news/endorsement_of_wp29_documents_en_0.pdf.

24 The guidelines on the calculation of fines are currently only available in English.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

18/25

2. In this case

2.1 Regarding the imposition of an administrative fine

59. In the communication of grievances, the head of the investigation proposes to the Restricted Formation to impose an administrative fine of 5,330 euros against the controlled entity.

2.1.1 On the appropriateness of imposing an administrative fine

60. In order to decide whether to impose an administrative fine, the Restricted Formation analyzes the criteria set out in Article 83(2) of the GDPR.

61. Regarding the nature and severity of the breach (Article 83(2)(a) of the GDPR), it recalls concerning the infringement of Article 32(1) of the GDPR that in light of the risks posed by breaches of personal data, the European legislator intended to strengthen the obligations of data controllers regarding the security of processing. Thus, according to Recital (83) of the GDPR and in order to "ensure security and prevent any processing carried out in violation of this Regulation, it is important that the data controller or the processor assesses the risks inherent in the processing and implements measures to mitigate them, such as encryption. These measures should ensure an appropriate level of security, including confidentiality, taking into account the state of the art and the costs of implementation in relation to the risks and the nature of the personal data to be protected. [...]"

However, as the personal data of the complainant was unlawfully transferred in 2020, 2021, and in February 2022 by the controlled entity to Company X, the Restricted Formation believes that it did not assess the importance of securing the personal data contained in the information system of the data controller to which it has access to process the complainant's data on its behalf.

62. Regarding the duration criterion (Article 83(2)(a) of the GDPR), the Restricted Formation notes that the controlled entity confirmed during the Restricted Formation session on April 27, 2023, that the irregular transmissions of the complainant's [data] to Company X were related to

25 Communication of grievances, points 46 to 53 and 55.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

to an internal IT problem and that this update in the IT system of Company B [...], would have been made in March 2022.

However, no documentation submitted to the Restricted Formation contains evidence attesting that the controlled entity has since implemented appropriate technical and organizational measures to prevent the transfer of the complainant's data to Company X, so that the violation has therefore persisted since the termination of the complainant's contract on June 30, 2019. From that date, the controlled entity, as a subcontractor of the controlled entity, should have ceased transferring the complainant's personal data to Company X.

63. Regarding the number of affected individuals and the level of harm they have suffered (Article 83.2 a) of the GDPR), the Restricted Formation notes that the complainant is the only person known to the CNPD as having been affected by the violations of the GDPR by the controlled entity.

64. Concerning the harm suffered by the complainant, Recital (75) of the GDPR specifies that it is not only about physical and material damages but also moral damages. By frequently and unlawfully transmitting the complainant's data to Company X for publication [on its site], any internet user had access to her [data], without her consent. The complainant has even been contacted several times as part of religious telemarketing.

65. As for whether the violations were committed intentionally or negligently (Article 83.2.b) of the GDPR), the Restricted Formation recalls that "intention," meaning an offense committed intentionally, includes both knowledge and will concerning the characteristics of an offense, while "non-intentionally" (negligently) means that there was no intention to commit the violation, although the data controller or the subcontractor did not comply with the duty of care imposed on them by law.

The Restricted Formation finds that irregular transmissions of the complainant's data by the controlled entity on behalf of Company B to Company X for publication [on its site] occurred in 2020, 2021, and in February 2022.

While the Restricted Formation believes that the facts and violations observed do not reflect an intentional desire to violate the GDPR on the part of the controlled entity, it nevertheless considers that the violations were committed negligently.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

66. Regarding the measures taken by the controlled entity to mitigate the harm suffered by the affected individuals (Article 83.2.c), the Restricted Formation takes into account the measures taken by the controlled entity and refers to Chapter II.3, Section 2.2 of this decision for related explanations.

67. It also notes that while several measures have been implemented by the controlled entity to remedy fully or partially certain violations, these were only adopted following the launch of the investigation by the CNPD agents on August 23, 2022 26 (see also point 57 of this decision).

68. Regarding the degree of responsibility of the subcontractor, considering the technical and organizational measures it has implemented under Articles 25 and 32 (Article 83.2.d) of the GDPR), the Restricted Formation takes into account that the complainant's data was not only unlawfully transferred in 2020 but also in 2021, as well as in February 2022. Furthermore, it notes that the requests for deletion of the complainant's data by Company X on October 19, 2020, and March 29, 2021, should have led the controlled entity to conduct investigations into its security system in accordance with

Article 32 of the GDPR, which it did not do.

69. Regarding the degree of cooperation established with the supervisory authority (Article 83.2 f) of the GDPR), the Restricted Formation takes into account the statement of the head of the investigation "that it was necessary, several times during the investigation, to send reminders by letters and emails to the Controlled to obtain responses to its questions." 27

70. Regarding the categories of personal data concerned by the violation (Article 83.2. g) of the GDPR), these are [the data] of the complainant unlawfully transferred multiple times by the controlled entity on behalf of Company B to Company X to appear [on its website].

71. Regarding how the CNPD became aware of the violation (Article 83.2 h) of the GDPR), the CNPD was informed of the facts constituting the violation as part of the complaint filed by the complainant.

72. The Restricted Formation finds that the other criteria of Article 83.2 of the GDPR are neither relevant nor likely to influence its decision regarding the imposition of an administrative fine and its amount.

26 Sending of the opening of the investigation with the initial findings.

27 Communication of the grievances, point 49.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

21/25

73. Consequently, the Restricted Formation considers that the imposition of an administrative fine is justified in light of the criteria set forth in Article 83.2 of the GDPR for violations of Articles 31 and 32.1 of the GDPR.

2.1.2. On the amount of the fine

74. The subject of the investigation indicated that it had achieved a turnover of [...] € for the year 2021, and a net profit of [...] € for the year 2021.²⁸ It has a workforce of more than [...] employees [...], and more than [...] private and professional clients.²⁹

75. Regarding the amount of the administrative fine, the Restricted Formation recalls that Article 83.3 of the GDPR provides that in the case of multiple violations, as is the case here, the total amount of the fine may not exceed the maximum amount set for the most serious violation. Since a violation of Articles 31 and 32.1 of the GDPR is attributed to the subject of the investigation, the maximum amount of the fine that can be imposed is 10 million euros or 2% of the total global annual turnover, with the higher amount being retained, in accordance with Article 83.5 of the GDPR.

76. In light of the responsibility of the subject of the investigation, its financial capacities, and the relevant criteria of Article 83.2 of the GDPR mentioned above in the chapter "2.1.1 On the appropriateness of imposing an administrative fine," the Restricted Formation considers that the imposition of a fine of two thousand five hundred (2,500) euros is both effective, proportionate, and deterrent, in accordance with the requirements of Article 83.1 of the GDPR.

2.2 Regarding the implementation of corrective measures

77. In the communication of grievances³⁰ the head of the investigation proposed to the Restricted Formation

to adopt the following corrective measures "within a period of 1 month from the notification to the Subject of the decision taken by the Restricted Formation, under penalty of a fine of 50 euros per day of delay:

" • Order the Subject to permanently cease the processing of personal data of the Claimant consisting of a transfer of said data to Company X;

28 See the letter dated October 7, 2022, in which the subject of the investigation indicated the following [...].

29 Information available on the website of the subject of the investigation: [...].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

22/25

- Order the Subject to implement sufficient technical and organizational measures to ensure the confidentiality of personal data as well as a procedure to regularly test, analyze, and evaluate the effectiveness of said measures;
- Remind the Subject of its obligation to cooperate with the CNPD."

78. Regarding the corrective measures proposed by the head of the investigation and by reference to point 58 of this decision, the Restricted Formation takes into account the steps taken by the subject of the investigation to comply with the provisions of Articles 32.1 and 31 of the GDPR, as detailed in its letters of October 7, 2022, and December 14, 2022.

In particular, it notes the following facts:

-

Regarding the corrective measure proposed by the head of the investigation mentioned in the first bullet point of

point 77 of this decision concerning the permanent cessation of the processing of personal data of the claimant consisting of a transfer of said data to Company X, the subject of the investigation indicated in its letter of December 14, 2022, that it had taken into account the request from Company X to remove the claimant from the lists [...] and that consequently, the claimant "was indeed removed from our lists as of May 28, 2021."

However, the Restricted Formation notes, as mentioned in point 31, that the subject of the investigation sent in this same letter of December 14, 2022, among other things, the email and the file [...] sent on February 15, 2022, to Company X containing again the [data] of the claimant.

During the Restricted Formation meeting on April 27, 2023, the subject of the investigation confirmed that, contrary to previous assertions, the [data] of the claimant were indeed still present in the file transmitted in February 2022 to Company X. It explained that these irregular transmissions were related to an internal IT problem, as at the time when the claimant's subscription with Company B ended in 2019, the registration in the client file [...] was not automatically deleted. According to the subject of the investigation, this update in the IT system of Company B [...] would not have been made until March 2022.

It indeed notes that the letter from the subject of the investigation dated December 14, 2022, is accompanied by an email from Company X dated March 8, 2022, requesting the subject of the investigation not to include the [data] of the claimant in the lists [...], on the one hand, as well as the files transmitted by the subject of the investigation to Company X from April to October 2022, which no longer contain the [data] of the claimant, on the other hand.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

23/25

However, no documentation submitted to the Restricted Formation contains evidence that the controlled entity has now implemented appropriate technical and organizational measures allowing it to verify compliance with the provisions of the GDPR in order to avoid transferring the complainant's data to Company X on behalf of Company B again.

In consideration of the insufficient compliance measures taken by the controlled entity in this case and point 58 of this decision, the Restricted Formation therefore considers it necessary to impose the corrective measure proposed by the head of the investigation in this regard, as reiterated in the first bullet point of point 77 of this decision.

-

Regarding the corrective measure proposed by the head of the investigation reiterated in the second bullet point of point 77 of this decision concerning the implementation of sufficient technical and organizational measures to ensure the confidentiality of personal data as well as a procedure aimed at regularly testing, analyzing, and evaluating the effectiveness of said measures, the controlled entity confirmed during the session of the Restricted Formation on April 27, 2023, that the irregular transmissions of the complainant's [data] to Company X were related to an internal IT problem and that this update in the IT system of Company B [...] would not have been made until March 2022.

However, no documentation submitted to the Restricted Formation contains evidence that the controlled entity has established a specific procedure to regularly test and analyze whether the lists of [data] it transmits to Company X on behalf of Company B do not include subscribers who have either terminated their subscription contract with Company B or requested to no longer appear [on the site] in order to ensure data security and meet the minimum necessary security requirements.

In consideration of the insufficient compliance measures taken by the controlled entity in this case and point 58 of this decision, the Restricted Formation therefore considers it necessary to impose the corrective measure proposed by the head of the investigation in this regard, as reiterated in the first bullet point of point 77 of this decision.

-

Regarding the corrective measure proposed by the head of the investigation reiterated in the third bullet point of point 77 of this decision concerning the reminder to the controlled entity regarding its obligation to cooperate with the CNPD, the Restricted Formation noted that the CNPD had to contact the controlled entity several times in 2021 and 2022 and even sent reminder letters without response. It was therefore of the opinion that at the beginning of the investigation, Article 31 of the GDPR was not respected by the controlled entity, as it failed to fulfill its obligation to cooperate with the supervisory authority, namely, the CNPD.

For these reasons, the Restricted Formation considers it necessary to impose the corrective measure proposed by the head of the investigation in this regard, as reiterated in the third bullet point of point 77 of this decision, and to remind the controlled entity for violating Article 31 of the GDPR.

-

The Restricted Formation further considers that there is no need to impose a penalty on the controlled entity to compel it to comply with these corrective measures.

In light of the preceding developments, the National Commission sitting in a restricted formation, after deliberation, decides:

-

to acknowledge the violations of Articles 31 and 32.1 of the GDPR;

-

to impose an administrative fine of two thousand five hundred (2,500) euros against "Company A" for the violations of Articles 31 and 32.1 of the GDPR;

-

to impose a permanent prohibition on "Company A" regarding the processing of the complainant's personal data consisting of a transfer of said data to Company X;

-

to order "Company A" to bring its processing into compliance with the obligations arising from Article 32.1 of the GDPR, within a period of two months following the notification of the decision of the restricted formation, and, in particular, to implement sufficient technical and organizational measures

to ensure the confidentiality of the complainant's personal data as well as a procedure aimed at regularly testing, analyzing, and evaluating the effectiveness of said measures.

-

to remind "Company A" for violating Article 31 of the GDPR.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with the company "Company A"

25/25

Belvaux, July 5, 2023.

The National Commission for Data Protection sitting in a restricted formation

Tine A. Larsen Thierry Lallemand

Marc Lemmer

President

Commissioner

Commissioner

Indication of remedies

This administrative decision may be subject to an appeal for reform within three months following its notification. This appeal must be brought before the administrative court and must necessarily be introduced through a lawyer at the Court of one of the Bar Associations.